CLOUD FORESNSIC INVESTIGATION

PREPARED BY: ELIZABETH NWOFOR

ROLE: LEAD CLOUD FORENSIC ENGINEER

EXECUTIVE SUMMARY

A forensic investigation was conducted on AWS CloudTrail logs following a suspected cloud compromise. The analysis revealed that an attacker successfully compromised an IAM access key, escalated privileges, accessed sensitive data, and established persistence within the environment.

The attacker demonstrated advanced techniques including:

- Credential abuse
- Privilege escalation
- Data exfiltration
- Backdoor creation
- Log evasion tactics

The attack originated from an external IP and later transitioned to a secondary IP for persistence and stealth operations.

METHODOLOGY

The investigation followed a structured forensic approach:

- Log Analysis

CloudTrail logs were parsed and analyzed chronologically to reconstruct attacker activity.

- Event Correlation

Events were grouped based on:

- Access Key ID usage
- Source IP addresses
- API call patterns

- Threat Hunting

Suspicious behaviors were identified based on:
Unusual API calls (e.g., PutUserPolicy, CreateUser)
Access from external/public IPs
Access to sensitive services (S3, Secrets Manager, IAM)

- Data Decoding

Base64-encoded strings were decoded to reveal hidden or obfuscated information.

- Behavioral Analysis

Normal system activity was separated from malicious activity using:

- Known AWS internal IP ranges
- Expected service behavior
- User activity baselines

```
    {
        "eventTime": "2026-04-20T01:00:05Z",
        "eventSource": "ec2.amazonaws.com",
        "eventName": "DescribeInstances",
        "awsRegion": "us-east-1",
        "sourceIPAddress": "172.31.45.12",
        "userAgent": "aws-internal/3",
        "userIdentity": {
            "type": "AssumedRole",
            "principalId": "AROA:SystemMonitor"
        }
    },
    {
        "eventTime": "2026-04-20T01:05:22Z",
        "eventSource": "s3.amazonaws.com",
        "eventName": "GetBucketLogging",
        "awsRegion": "us-east-1",
        "sourceIPAddress": "52.94.23.11",
        "userAgent": "S3Console/0.1",
        "userIdentity": {
            "type": "IAMUser",
            "userName": "admin_backup"
        }
    },
    {
        "eventTime": "2026-04-20T01:10:00Z",
        "eventSource": "lambda.amazonaws.com",
        "eventName": "GetFunction",
        "awsRegion": "us-west-2",
        "sourceIPAddress": "10.0.1.55",
        "userAgent": "Boto3/1.26.1",
        "userIdentity": {
            "type": "AssumedRole",
            "principalId": "AROA:LambdaExec"
        }
    },
    {
        "eventTime": "2026-04-20T01:15:33Z",
        "eventSource": "sts.amazonaws.com",
```


Ln 455, Col 26 Spaces: 4 UTF-8 CRLF { } JSON

Json view of cloudtrail log

REQUIRED DELIVERABLES

1. Credentials Discovery

The access key **AKIA_DEV_PROD_9982** is the primary credential used by the attacker for the bulk of the attack. It first appears at 01:15:33Z when an external IP (190.45.112.3) uses it to call *GetCallerIdentity* — an attacker's standard first step to verify that a stolen key is valid and determine what account it belongs to.

This key was then used continuously from 190.45.112.3 to conduct reconnaissance, privilege escalation, data exfiltration, and backdoor creation. It was eventually deactivated by the attacker themselves at 04:50:33Z using the backdoor key, to cover their tracks and prevent defenders from using the same key to investigate.


```
    },
    {
        "eventTime": "2026-04-20T01:15:33Z",
        "eventSource": "sts.amazonaws.com",
        "eventName": "GetCallerIdentity",
        "awsRegion": "us-east-1",
        "sourceIPAddress": "190.45.112.3",
        "userAgent": "aws-cli/2.0.30",
        "userIdentity": {
            "type": "IAMUser",
            "accessKeyId": "AKIA_DEV_PROD_9982"
        }
    },
```


2. IP Forensic Tracking

Initial Attacker IP:

IP **190.45.112.3** is the initial attack IP. It first appears at 01:15:33Z using access key AKIA_DEV_PROD_9982 to call *GetCallerIdentity* — the attacker's way of verifying the stolen key works and identifying what AWS account they have access to. This IP is clearly external and not attributable to any known internal service.

Second Attacker IP

IP **45.33.10.11** first appears at 03:35:45Z performing CreateAccessKey for the backdoor user

support_service_backup. This IP represents a second operational base the attacker. The attacker used this IP to aviod detection

— specifically for persistence and escalation operations. The use of a second IP is a deliberate operational security (OPSEC) measure to separate the initial compromise activity from the persistence phase, making correlation harder.


```
},
{
    "eventTime": "2026-04-20T03:35:45Z",
    "eventSource": "iam.amazonaws.com",
    "eventName": "CreateAccessKey",
    "awsRegion": "us-east-1",
    "sourceIPAddress": "45.33.10.11",
    "userAgent": "Mozilla/5.0 (X11; Linux x86_64)",
    "userIdentity": {
        "accessKeyId": "AKIA_DEV_PROD_9982"
    },
    "requestParameters": {
        "userName": "support_service_backup"
    }
```


3. Obfuscated Data Analysis

Two Base64 encoded strings were identified in the CloudTrail logs. Both were deliberately embedded to either hide malicious data or store legitimate configuration. The investigation decoded both using CyberChef.

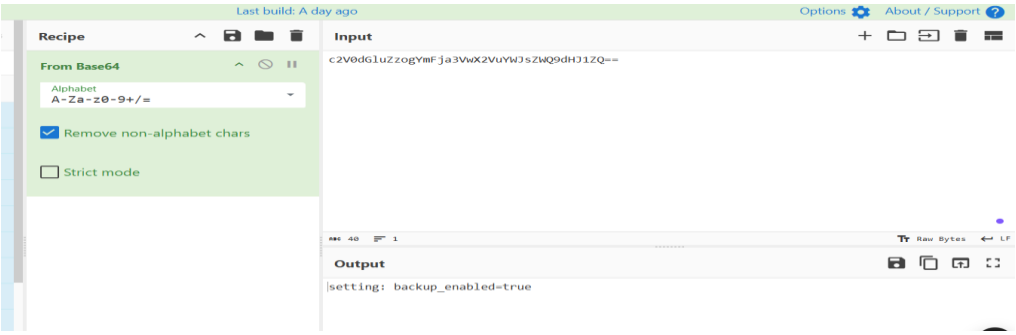
String 1: Legitimate

Encoded: c2V0dGluZzogYmFja3VwX2VuYWJsZWQ9dHJ1ZQ==

Decoded: setting: backup_enabled=true


```
58  {
59      "eventTime": "2026-04-20T01:23:45Z",
60      "eventSource": "s3.amazonaws.com",
61      "eventName": "PutObject",
62      "awsRegion": "us-east-1",
63      "sourceIPAddress": "10.0.1.55",
64      "userAgent": "DevOps-Deployer/1.0",
65      "requestParameters": {
66          "bucketName": "app-configs",
67          "key": "prod_config.ini",
68          "content": "c2V0dGluZzogYmFja3VwX2VuYWJsZWQ9dHJ1ZQ=="
69      }
```


This is a routine DevOps configuration deployment. The source IP 10.0.1.55 is an internal address using the DevOps-Deployer tool. The decoded value 'setting: backup_enabled=true' is a harmless configuration flag. The Base64 encoding here is standard practice for embedding configuration content in API parameters.



String 2: Not Legitimate (Malicious)

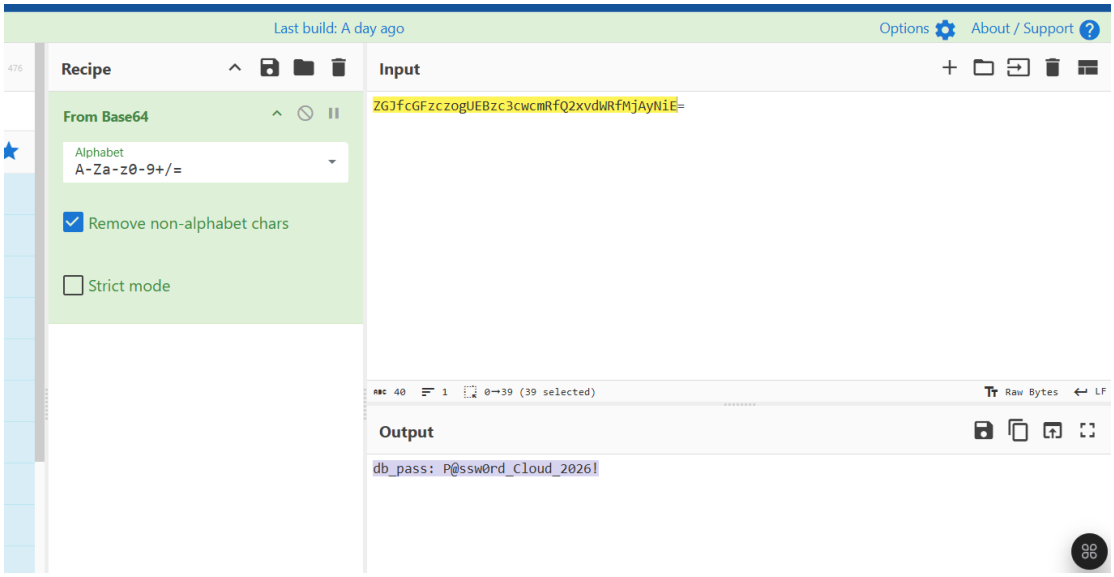
Encoded: ZGJfcGFzczogUEBzc3cwcmRfQ2xvdWRfMjAyNiE=

Decoded: db_pass: P@ssw0rd_Cloud_2026!

```
255    {
256        "eventTime": "2026-04-20T03:02:11Z",
257        "eventSource": "secretsmanager.amazonaws.com",
258        "eventName": "GetSecretValue",
259        "awsRegion": "us-east-1",
260        "sourceIPAddress": "190.45.112.3",
261        "userAgent": "aws-cli/2.0.30",
262        "userIdentity": {
263            "accessKeyId": "AKIA_DEV_PROD_9982"
264        },
265        "responseElements": {
266            "secretString": "ZGJfcGFzczogUEBzc3cwcmRfQ2xvdWRfMjAyNiE="
267        }
268    },
```


The attacker used the stolen key from their IP (190.45.112.3) to retrieve a secret from AWS Secrets Manager.The decoded value reveals a live database password: **P@ssw0rd_Cloud_2026!**

This credential gives the attacker access to the organisation's database — entirely separate from AWS. This is a critical secondary breach: the attacker now has both cloud access AND database credentials



Comparison of both string

Attibutes	String 1	String 2
Encoded Value	c2V0dGluZzogYmFja3VwX2VuYWJsZWQ9dHJ1ZQ==	ZGJfcGFzczogUEBzc3cwcmRfQ2xvdWRfMjAyNiE=
Decoded Value	setting: backup_enabled=true	db_pass: P@ssw0rd_Cloud_2026!
Source IP	10.0.1.55 (internal DevOps)	190.45.112.3 (external attacker)
Access Key	DevOps-Deployer/1.0 (tool-based)	AKIA_DEV_PROD_9982 (stolen)
Event Type	PutObject (writing config)	GetSecretValue (reading secret)

4. Administrative Escalation

At 02:50:33Z, the attacker used the stolen key AKIA_DEV_PROD_9982 from IP 190.45.112.3 to call PutUserPolicy on the IAM user dev_user_musa named 'FullAdmin' to the user dev_user_musa with the following policy document:

```
"{\"Statement\": [{\"Effect\":\"Allow\",\"Action\":\"*\",\"Resource\":\"*\"}]}"
```

This policy translates to: allow ALL actions on ALL resources in the entire AWS account. By attaching this to dev_user_musa, the attacker elevated that user, who was already associated with the stolen key — to full administrator level, removing all permission boundaries and enabling every subsequent

malicious action including secret extraction, S3 data access, backdoor user creation, and CloudTrail manipulation attempts.


```
{
    "eventTime": "2026-04-20T02:50:33Z",
    "eventSource": "iam.amazonaws.com",
    "eventName": "PutUserPolicy",
    "awsRegion": "us-east-1",
    "sourceIPAddress": "190.45.112.3",
    "userAgent": "aws-cli/2.0.30",
    "userIdentity": {
        "accessKeyId": "AKIA_DEV_PROD_9982"
    },
    "requestParameters": {
        "userName": "dev_user_musa",
        "policyName": "FullAdmin",
        "policyDocument": "{\"Statement\": [{\"Effect\":\"Allow\",\"Action\":\"*\",\"Resource\":\"*\"}]}"
    }
},
```


Before this action, the attacker could only perform actions that the stolen key's original permissions allowed. After this single API call, they had unrestricted access to the entire AWS environment — equivalent to being the root account user.

5. The Theft

At 03:10:44Z, the attacker downloaded the file **ceo_personal_taxes_2025.pdf** from the S3 bucket **top-secret-financials-2026** using the stolen access key from their primary attack IP. This represents confirmed data exfiltration.


```
{
    "eventTime": "2026-04-20T03:10:44Z",
    "eventSource": "s3.amazonaws.com",
    "eventName": "GetObject",
    "awsRegion": "us-east-1",
    "sourceIPAddress": "190.45.112.3",
    "userAgent": "aws-cli/2.0.30",
    "userIdentity": {
        "accessKeyId": "AKIA_DEV_PROD_9982"
    },
    "requestParameters": {
        "bucketName": "top-secret-financials-2026",
        "key": "ceo_personal_taxes_2025.pdf"
    }
```


The attacker first performed ListObjects on the same bucket at 03:00:15Z about nine minutes before the download — to enumerate the bucket's contents and identify the most sensitive file before targeting it specifically.


```
{
    "eventTime": "2026-04-20T03:00:15Z",
    "eventSource": "s3.amazonaws.com",
    "eventName": "ListObjects",
    "awsRegion": "us-east-1",
    "sourceIPAddress": "190.45.112.3",
    "userAgent": "aws-cli/2.0.30",
    "userIdentity": {
        "accessKeyId": "AKIA_DEV_PROD_9982"
    },
    "requestParameters": {
        "bucketName": "top-secret-financials-2026"
    }
},
```


6. Persistence and Evasion

Back door user created


```
{
    "eventTime": "2026-04-20T03:15:22Z",
    "eventSource": "iam.amazonaws.com",
    "eventName": "CreateUser",
    "awsRegion": "us-east-1",
    "sourceIPAddress": "190.45.112.3",
    "userAgent": "aws-cli/2.0.30",
    "userIdentity": {
        "accessKeyId": "AKIA_DEV_PROD_9982"
    },
    "requestParameters": {
        "userName": "support_service_backup"
    }
```


At 03:15:22Z the attacker created a new IAM user named support_service_backup — a name deliberately chosen to look like a legitimate AWS service account. At 03:25:33Z they attached the AWS-managed AdministratorAccess policy to this user, giving it full account control. At 03:35:45Z, switching to a second IP (45.33.10.11), they created an access key for this backdoor user, generating the key AKIA_FAKE_BACKDOOR_KEY_7721.

```
{
    "eventTime": "2026-04-20T03:25:33Z",
    "eventSource": "iam.amazonaws.com",
    "eventName": "AttachUserPolicy",
    "awsRegion": "us-east-1",
    "sourceIPAddress": "190.45.112.3",
    "userAgent": "aws-cli/2.0.30",
    "userIdentity": {
        "accessKeyId": "AKIA_DEV_PROD_9982"
    },
    "requestParameters": {
        "userName": "support_service_backup",
        "policyArn": "arn:aws:iam::aws:policy/AdministratorAccess"
    }
```


Final Action - Deactivation of Original Stolen Key

Final Action Against Original Stolen Key: UpdateAccessKey → status: Inactive
Timestamp: 2026-04-20T04:50:33Z


```
468 {
469     "eventTime": "2026-04-20T04:50:33Z",
470     "eventSource": "iam.amazonaws.com",
471     "eventName": "UpdateAccessKey",
472     "awsRegion": "us-east-1",
473     "sourceIPAddress": "45.33.10.11",
474     "userAgent": "aws-cli/2.0.30",
475     "userIdentity": {
476         "accessKeyId": "AKIA_FAKE_BACKDOOR_KEY_7721"
477     },
478     "requestParameters": {
479         "accessKeyId": "AKIA_DEV_PROD_9982",
480         "status": "Inactive"
```


At 04:50:33Z, the attacker used their backdoor key (AKIA_FAKE_BACKDOOR_KEY_7721) to call UpdateAccessKey and set the original stolen key AKIA_DEV_PROD_9982 to Inactive status.
The attacker's final move was to deactivate the original stolen key AKIA_DEV_PROD_9982 using the backdoor key. The strategic reasoning is two fold:

- Remove the evidence trail: If defenders discover and revoke the original key, the attacker is still in (via the backdoor key). By deactivating it themselves first, they may delay the investigation — analysts may think the key was already revoked.
- Deny defenders re-use: Deactivating the key means the original user (and defenders) cannot use it to investigate or take remediation actions, buying the attacker more time.
- Maintain exclusive control: With the original key dead and the backdoor key active, only the attacker has privileged access — a full hostile takeover of the AWS environment

ATTACK CHAIN TIMELINE

Phase 1: Initaial Access and Reconnaissance

Timestamp	Source IP	Key used	Event	Meaning
01:15:33Z	190.45.112.3	AKIA_DEV_PROD_9982	sts:GetCallerIdentity	Verifies stolen key is valid; identifies AWS account
01:25:44Z	190.45.112.3	AKIA_DEV_PROD_9982	iam:GetAccountSummary	Maps account — number of users, groups, policies
01:40:00Z	190.45.112.3	AKIA_DEV_PROD_9982	s3:ListBuckets	Lists all S3 buckets — looking for sensitive storage
02:05:45Z	190.45.112.3	AKIA_DEV_PROD_9982	iam:ListUserPolicies	Targets dev_user_musa — checking their permissions
02:20:00Z	190.45.11	AKIA_DEV_PROD_9982	iam:ListAttachedUserPo	Further profiling

	2.3		licies	dev_user_musa for escalation target
02:30:10Z	190.45.112.3	AKIA_DEV_PROD_9982	sts:GetSessionToken	Gets temporary credentials for next phase
02:40:00Z	190.45.112.3	AKIA_DEV_PROD_9982	cloudtrail:DescribeTrails	Checks what logging is active before escalating

Phase 2 - Privilage Escalationand Credential Theft

Time stamp	Source IP	Event	Meaning
02:50:33Z	190.45.112.3	iam:PutUserPolicy — FullAdmin on dev_user_musa	FULL ADMIN GRANTED — Action:* Resource:* policy
03:00:15Z	190.45.112.3	s3:ListObjects — top-secret-financials-2026	Locating sensitive files before exfiltration
03:02:11Z	190.45.112.3	secretsmanager:GetSecretValue	Database password stolen: P@ssw0rd_Cloud_2026!
03:10:44Z	190.45.112.3	s3:GetObject — ceo_personal_taxes_2025.pdf	DATA EXFILTRATION — CEO personal tax file downloaded

Phase 3 - Backdoor creation and persistence

Time stamp	Source IP	Event	Meaning
03:15:22Z	190.45.112.3	iam:CreateUser — support_service_backup	Backdoor user created disguised as service account
03:25:33Z	190.45.112.3	iam:AttachUserPolicy — AdministratorAccess	Backdoor user given full AWS administrator access
03:35:45Z	45.33.10.11 (NEW IP)	iam:CreateAccessKey — support_service_backup	Backdoor key AKIA_FAKE_BACKDOOR_KEY_7721 created
03:40:00Z	45.33.10.11	cloudtrail:StopLogging — AccessDenied	Attempted to disable audit trail — BLOCKED

Phase 4 - Cover Track

Time stamp	Source IP	Event	Menaing
04:05:44Z	45.33.10.11	AKIA_FAKE_BACKDOOR_KEY_7721	sts:GetCallerIdentity
04:10:00Z	45.33.10.11	AKIA_FAKE_BACKDOOR_KEY_7721	s3:DeleteBucket — AccessDenied
04:35:44Z	45.33.10.11	AKIA_FAKE_BACKDOOR_KEY_7721	iam:GetAccountPasswordPolicy
04:50:33Z	45.33.10.11	AKIA_FAKE_BACKDOOR_KEY_7721	iam:UpdateAccessKey — AKIA_DEV_PROD_9982 set Inactive

Indicator of Compromise (IOCs)

Type	**Value**	**Context**
Attacker IP 1	190.45.112.3	Primary attack IP — all initial reconnaissance and escalation
Attacker IP 2	45.33.10.11	Persistence IP — backdoor creation and key deactivation
Stolen Access Key	AKIA_DEV_PROD_9982	Compromised

		developer/production key used for bulk of attack
Backdoor Access Key	AKIA_FAKE_BACKDOOR_KEY_7721	Attacker-created persistence credential
Backdoor IAM User	support_service_backup	Malicious IAM user with AdministratorAccess
Stolen Secret	db_pass: P@ssw0rd_Cloud_2026!	Database password extracted from Secrets Manager
Exfiltrated File	ceo_personal_taxes_2025.pdf	CEO personal tax document stolen from top-secret-financials-2026
Malicious Policy	FullAdmin — Action:* Resource:*	Inline policy applied to dev_user_musa for full escalation

RECOMMENDATION

Containment

- Deactivate and revoke AKIA_DEV_PROD_9982 and AKIA_FAKE_BACKDOOR_KEY_7721 immediately.
- Disable and delete IAM user support_service_backup and all its associated keys and policies.
- Remove the FullAdmin inline policy from dev_user_musa.
- Rotate the database password db_pass: P@ssw0rd_Cloud_2026! across all systems using it.
- Audit who has accessed the top-secret-financials-2026 bucket and notify affected parties of the CEO personal tax document breach.

Investigation

- Notify the CEO that their personal tax document (ceo_personal_taxes_2025.pdf) has been exfiltrated — this may require legal and regulatory notification.
- Determine how the key AKIA_DEV_PROD_9982 was originally stolen — check developer machines, code repositories, and CI/CD pipelines for exposed credentials.
- Review S3 bucket top-secret-financials-2026 permissions — it should not be accessible via standard developer keys.

CONCLUSION

This investigation confirms a complete, multi-stage AWS account compromise. The threat actor demonstrated significant operational sophistication: they conducted deliberate reconnaissance before escalating, used obfuscated credentials to obscure critical stolen data in plain sight, pivoted IP addresses at key moments, created a convincingly named backdoor account, and attempted to erase their tracks by disabling audit logging and deactivating the original stolen key. The compromise resulted in the exfiltration of highly sensitive PII (the CEO's personal tax return) and a critical database credential.